ATÖLYEKART · AHŞAP ATÖLYESİ · 6 HAFTALIK PROJE

Hafta 2 Özeti

Hafta 1'de React ile kurulan katalog sitesi bu hafta canlıya çıktı, sunucu tarafı ve güvenlik katmanları eklendi, ardından mobil uygulamaya taşındı.

7	12	10–11 Ekim	0
ödev	commit	2026	kritik güvenlik bulgusu

Ödevler

Git + worktree ile paralel geliştirme 2.1

Aynı depoda iki iş aynı anda yürütüldü. `main`'de bir hata düzeltildi, ayrı bir worktree'de (`ozellik/kategori-filtresi`) yeni bir özellik geliştirildi, sonra iki iş birleştirildi.

- **Hata düzeltmesi:** e-posta alanı `ayse@gmail` gibi noktasız alan adlarını kabul ediyordu. Kural `src/data/formRules.js`'te tek bir yerde toplandı.
- **Kategori filtresi:** ürünler Tümü / Kuksalar / Kaşıklar olarak süzülebiliyor (`CategoryFilter`, `categories.js`).

Vercel ile deploy 2.2

Site Vercel CLI ile yayına alındı: `atolyekart-murex.vercel.app`. Vercel derlemesinde `base: '/'`, GitHub Pages derlemesinde `/AtolyeCard/` kullanılıyor. İki yayın birlikte açık duruyor.

Webhook secret'ı sunucuya taşındı 2.3

Daha önce webhook adresi tarayıcıya gömülü olduğu için herkes görebiliyordu. Artık tarayıcı yalnızca kendi sunucusuna istek atıyor, adresi sunucu ekliyor.

Tarayıcı → POST /api/webhook → server/forwardWebhook.js → WEBHOOK_URL

- Gizli değerlerde `VITE_` öneki kullanılmıyor, bu yüzden tarayıcı bundle'ına girmiyorlar.
- Geliştirme ortamında `.env.development.local`, production'da yalnızca Vercel panelindeki değerler kullanılıyor. Canlıda test edildi.

JWT ve rate limit 2.4

- `GET /api/order-token` 15 dakika geçerli, HS256 ile imzalı bir sipariş token'ı üretiyor (`jose`).
- `POST /api/webhook` sipariş isteklerinde Bearer token istiyor, token yoksa 401 dönüyor.
- Her IP dakikada en fazla 10 istek atabiliyor, fazlası `429` ve `Retry-After` alıyor (`server/rateLimit.js`).
- Uç noktalar `server/handlers.js`'te. Vercel fonksiyonları ve Vite geliştirme eklentisi aynı kodu kullanıyor.

KVKK açık rıza ve aydınlatma metni 2.5

İki forma da zorunlu bir rıza kutusu eklendi (`ConsentCheckbox`). Payload'da `consent: true` gönderiliyor ve sunucu bu alan olmadan isteği kabul etmiyor. Aydınlatma metni taslağı `/#gizlilik` adresinde (`PrivacyPolicy`).

Deploy öncesi güvenlik checklist'i 2.6

Sekiz maddelik kontrol listesinin tamamı geçti (`docs/guvenlik-checklist.md`). Başlıca adımlar:

- `vercel.json`'a güvenlik başlıkları eklendi: CSP, `X-Frame-Options: DENY`, Referrer-Policy, Permissions-Policy.
- Sunucuda girdi temizleme eklendi (`sanitizePayload.js`). Payload yeniden kuruluyor, fazladan alanlar atılıyor, uzunluk ve desen sınırları uygulanıyor.
- `npm audit` sonucu 0 açık. 34 açığın kaynağı olan `vercel` CLI projeden çıkarıldı, deploy artık `npx` ile yapılıyor.
- Strix taraması yapıldı (aşağıda).

Expo mobil port 2.7

Site React Native'e (Expo SDK 57) taşındı (`mobile/`). Ürün verisi ve form kuralları web ile ortak, `../src/data`'dan okunuyor. Formlar canlı Vercel API'sine gönderiyor. Expo Go ile telefonda denendi: sipariş ve stok bildirimi canlı webhook'a ulaştı.

Güvenlik durumu

Kontrol	Sonuç
Secret'lar git'te ve tarayıcıda değil	✓ Geçti
Çift gönderim engeli, HTTPS ve güvenlik başlıkları	✓ Geçti
`npm audit` (web)	✓ 0 açık
`standart-denetcisi` taraması	✓ Kritik/yüksek bulgu yok, orta bulgular düzeltildi
Strix taraması (quick, 1,85 $)	✓ Kritik/yüksek yok, 1 orta bulgu düzeltildi

Strix'in bulduğu orta seviye açık: aynı sipariş token'ı 15 dakika içinde birden fazla siparişte kullanılabiliyordu. Token'a `jti` eklendi, artık her token yalnızca bir kez kullanılabiliyor.

Açık kalanlar

- **KVKK yer tutucuları:** veri sorumlusu, bildirim hizmeti ve saklama süresi henüz doldurulmadı. Gerçek kullanımdan önce doldurulmalı ve hukukçuya kontrol ettirilmeli.
- **Rate limit ve harcanan token listesi bellekte tutuluyor:** her sunucu örneğinin kendi sayacı var. Kesin bir sınır için Redis gibi ortak bir depo gerekir.
- **Mobil bağımlılıklar:** `npm audit` 22 açık gösteriyor, hepsi Expo ve React Native alt bağımlılıklarında. Expo güncellemesi bekleniyor.